

REPORT TECNICO DI SICUREZZA: ENUMERAZIONE DEI SERVIZI E ANALISI DEI PROCESSI

Ambiente target: CyberOps Workstation (Linux)

Account di Test: analyst

Fase Operativa: Information Gathering & Attack Surface Mapping

Perché è stato necessario eseguire `ps` come root (premettendo il comando con `sudo`)?

È necessario premettere `sudo` (che conferisce temporaneamente i privilegi massimi di amministratore) per ragioni di sicurezza legate al principio del **Least Privilege** (Privilegio Minimo).

Un utente standard, come l'account `analyst`, potrebbe non avere l'autorizzazione per ispezionare i dettagli dei processi appartenenti ad altri utenti o quelli critici avviati dal sistema operativo. L'utilizzo di `root` bypassa queste restrizioni, garantendo all'analista una visibilità totale e senza filtri su tutto ciò che è in esecuzione sulla macchina, un requisito fondamentale durante l'attività di *Information Gathering* o la ricerca di malware.

Come viene rappresentata la gerarchia dei processi da `ps`?

Come si può osservare chiaramente nell'ultima colonna a destra (CMD) la gerarchia dei processi viene rappresentata tramite **l'indentazione visiva del testo**.

I processi "figli" (quelli generati e avviati da un altro programma) sono rientrati verso destra e posizionati immediatamente sotto il loro processo "padre".

Nelle righe evidenziate in arancione, puoi notare esattamente questa struttura: il primo processo `nginx` (il master, PID 395) è allineato a sinistra, mentre il secondo processo `nginx` (il worker, PID 396) è indentato, indicando visivamente che è stato generato (spawnato) dal primo.

```
[analyst@secOps ~]$ sudo /usr/sbin/nginx
[analyst@secOps ~]$ sudo ps -ejH
[sudo] password for analyst:
  PID  PGID  SID  TTY          TIME CMD
    1      1    1  ?          00:00:00 systemd
   167   167  167  ?          00:00:01 systemd-journal
   193   193  193  ?          00:00:00 systemd-udevd
   209   209  209  ?          00:00:00 rsyslogd
   210   210  210  ?          00:01:41 java
   212   212  212  ?          00:00:01 ovsdb-server
   213   213  213  ?          00:00:00 start_pox.sh
   224   213  213  ?          00:01:18 python2.7
   214   214  214  ?          00:00:00 systemd-logind
   216   216  216  ?          00:00:01 dbus-daemon
   221   221  221  ?          00:00:05 filebeat
   239   239  239  ?          00:00:05 VBoxService
   287   287  287  ?          00:00:00 ovs-vswitchd
   382   382  382  ?          00:00:00 dhcpcd
   387   387  387  ?          00:00:00 lightdm
   410   410  410  tty7       00:00:10 Xorg
   460   387  387  ?          00:00:00 lightdm
   492   492  492  ?          00:00:00 sh
   503   492  492  ?          00:00:00 xfce4-session
   513   492  492  ?          00:00:00 xfwm4
   517   492  492  ?          00:00:00 Thunar
  1592   492  492  ?          00:00:00 thunar-volman
   519   492  492  ?          00:00:00 xfce4-panel
   554   492  492  ?          00:00:00 panel-6-systray
   559   492  492  ?          00:00:00 panel-2-actions
   523   492  492  ?          00:00:01 xfdesktop
   530   492  492  ?          00:00:00 polkit-gnome-au
   395   395  395  ?          00:00:00 nginx
   396   395  395  ?          00:00:00 nginx
   408   384  384  ?          00:01:58 java
   414   414  414  ?          00:00:00 accounts-daemon
   418   418  418  ?          00:00:00 polkitd
<some output omitted>
```

Qual è il significato delle opzioni -t, -u, -n, -a e -p in netstat? (usa man netstat per rispondere)

Consultando il manuale di sistema (man netstat):

- **-t (tcp):** Mostra solo i socket e le connessioni che utilizzano il protocollo TCP.
- **-u (udp):** Mostra solo i socket e le connessioni che utilizzano il protocollo UDP.
- **-n (numeric):** Forza la visualizzazione degli indirizzi IP e dei numeri di porta in formato strettamente numerico (es. 80 invece di http), disabilitando la risoluzione DNS. Questo rende il comando più veloce e "silenzioso" a livello di rete.
- **-a (all):** Mostra tutti i socket attivi, includendo sia quelli con connessioni stabilite, sia quelli in stato di ascolto (LISTEN).
- **-p (program):** Aggiunge un'ultima colonna che mostra il PID (Process ID) e il nome del programma associato a quella connessione (richiede privilegi di root per visualizzare i processi altrui).

```
NETSTAT(8) Linux System Administrator's Manual NETSTAT(8)
NAME
    netstat - Print network connections, routing tables, interface statistics, masquerade connections, and multicast memberships
SYNOPSIS
    netstat [address_family_options] [--tcp|-t] [--udp|-u] [--udplite|-U] [--sctp|-S] [--raw|-w] [--l2cap|-Z] [--rfcomm|-F] [--listening|-l] [--all|-a] [--numeric|-n] [--numeric-ports]
    [--numeric-users] [--symbolic|-N] [--extend|-e|--extend|-e] [--timers|-o] [--program|-p] [--verbose|-v] [--continuous|-c] [--wide|-W]

    netstat [--route|-r] [address_family_options] [--extend|-e|--extend|-e] [--verbose|-v] [--numeric|-n] [--numeric-hosts] [--numeric-ports] [--numeric-users] [--continuous|-c]

    netstat [--interfaces|-i] [--all|-a] [--extend|-e|--extend|-e] [--verbose|-v] [--program|-p] [--numeric|-n] [--numeric-hosts] [--numeric-ports] [--numeric-users] [--continuous|-c]

    netstat [--groups|-g] [--numeric|-n] [--numeric-hosts] [--numeric-ports] [--numeric-users] [--continuous|-c]

    netstat [--masquerade|-M] [--extend|-e] [--numeric|-n] [--numeric-hosts] [--numeric-ports] [--numeric-users] [--continuous|-c]

    netstat [--statistics|-s] [--tcp|-t] [--udp|-u] [--udplite|-U] [--sctp|-S] [--raw|-w]

    netstat [--version|-V]

    netstat [--help|-h)

    address_family_options:

    [-4|--inet] [-6|--inet6] [--protocol={inet,inet6,unix,ipx,ax25,netrom,ddp,bluetooth, ...}] [--unix|-x] [--inet|--ip|--tcpip] [--ax25] [--x25] [--rose] [--ash] [--bluetooth] [--ipx] [--netrom]
    [--ddp|--appletalk] [--econet|--ec]
```

L'ordine delle opzioni è importante per netstat?

No, l'ordine è ininfluente. I sistemi Linux (conformi agli standard POSIX) permettono di raggruppare le singole opzioni a singola lettera dietro un unico trattino.

Scrivere `-tunap`, `-anput` o separarle come `-n -t -u -a -p` produrrà esattamente lo stesso identico output. Gli analisti usano spesso `-tunap` o `-anput` semplicemente perché sono sequenze facili da memorizzare e pronunciare.

```
[analyst@secOps ~]$ netstat -anput
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:6633            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 192.168.5.173:68       0.0.0.0:*               -           -

[analyst@secOps ~]$ netstat -ntupa
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:6633            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 192.168.5.173:68       0.0.0.0:*               -           -
```

Basandosi sull'output di netstat mostrato al punto (d), qual è il protocollo di Livello 4, lo stato della connessione e il PID del processo in esecuzione sulla porta 80?

In base alla riga evidenziata nell'output per la porta 80 (0.0.0.0:80):

- **Protocollo di Livello 4:** TCP (indicato nella colonna **Proto**)
- **Stato della connessione:** LISTEN (indicato nella colonna **State**)
- **PID del processo:** 395 (indicato nella colonna **PID/Program name** come 395/nginx: master)

```
[analyst@secOps ~]$ sudo netstat -tunap
[sudo] password for analyst:
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:6633            0.0.0.0:*               LISTEN      257/python2.7
tcp        0      0 0.0.0.0:80             0.0.0.0:*               LISTEN      395/nginx: master
tcp        0      0 0.0.0.0:21             0.0.0.0:*               LISTEN      279/vsftpd
tcp        0      0 0.0.0.0:22             0.0.0.0:*               LISTEN      277/sshd: /usr/bin
tcp6       0      0 :::22                  :::*                    LISTEN      277/sshd: /usr/bin
udp        0      0 192.168.1.15:68        0.0.0.0:*               237/systemd-network
```

Sebbene i numeri di porta siano solo una convenzione, puoi indovinare che tipo di servizio è in esecuzione sulla porta 80 TCP?

Sulla porta 80 TCP è in esecuzione un **servizio web (HTTP)**.

Per convenzione standard (assegnata dalla IANA), la porta 80 è dedicata al traffico internet in chiaro. Mostrando che la porta è gestita dal processo **nginx**, che è per l'appunto uno dei server web più popolari al mondo.

Il processo PID 395 è nginx. Come si potrebbe concludere questo dall'output sopra?

```
[analyst@secOps ~]$ sudo ps -elf | grep 395
[sudo] password for analyst:
 1 S root      395    1  0  80   0 - 1829   19:33 ?        00:00:00 nginx: master process /usr/bin/nginx
 5 S http     396   395  0  80   0 - 1866   19:33 ?        00:00:00 nginx: worker process
 0 S analyst  3789 1872  0  80   0 - 1190   19:53 pts/0    00:00:00 grep 395
```

L'ultima colonna a destra dell'output (relativa al comando eseguito) nella prima riga mostra esplicitamente la stringa **nginx: master process /usr/bin/nginx** in corrispondenza del PID 395 (la quarta colonna da sinistra).

Cos'è nginx? Qual è la sua funzione? Usa google per saperne di più su nginx)

Nginx è un server web open source ad altissime prestazioni. La sua funzione primaria è accettare le richieste HTTP/HTTPS dai client e servire pagine web, ma viene ampiamente utilizzato anche come *reverse proxy* e *load balancer* per gestire e distribuire il traffico di rete in infrastrutture complesse.

La seconda riga mostra che il processo 396 è di proprietà di un utente chiamato http e ha il processo numero 395 come processo genitore. Cosa significa? È un comportamento comune?

Sì, è un comportamento standard e rappresenta una pratica di sicurezza fondamentale nota come **Privilege Separation** (o *Privilege Dropping*). Il processo "padre" (PID 395) deve essere avviato dall'amministratore (**root**) perché Linux impedisce agli utenti normali di aprire porte di rete inferiori alla 1024 (come la porta 80). Una volta aperta la porta, il padre delega la gestione effettiva del traffico a processi "worker" (PID 396), declassandoli all'utente limitato **http**. Se un attaccante sfrutta una vulnerabilità del web server, otterrà solo i permessi dell'utente **http**, non il controllo del sistema (**root**).

Perché l'ultima riga mostra `grep 395`?

Quando esegui `ps -elf | grep 395`, stai lanciando i due comandi in contemporanea. Il programma `grep` diventa a tutti gli effetti un processo attivo per la frazione di secondo necessaria a filtrare l'output. Dato che la sua stringa di esecuzione contiene "395", `grep` finisce per trovare e stampare anche se stesso tra i risultati.

Perché l'errore è stato inviato come pagina web?

Il server Nginx restituisce l'errore sotto forma di pagina web perché è programmato per comunicare utilizzando il protocollo HTTP, il cui scopo finale è servire contenuti leggibili dai browser.

- **Standard di comunicazione:** Il compito di un server web è ricevere richieste e restituire risposte strutturate, che includono un codice di stato (es. 400) e un corpo (body) solitamente formattato in codice HTML.
- **Presunzione del client:** Nginx ignora che tu stia utilizzando Telnet per testare la connessione in formato testuale crudo; il suo comportamento predefinito assume che all'altro capo ci sia un normale browser web (come Chrome o Firefox).
- **Gestione degli errori (UX):** Inviando l'errore in HTML (come mostrato dai tag `<html><body><h1>400 Bad Request</h1>...`), il server garantisce che, in un'interazione standard, il browser dell'utente interpreti quel codice per mostrare a schermo un messaggio di errore graficamente comprensibile, invece di far cadere la connessione senza alcuna spiegazione.

```
[analyst@secOps ~]$ telnet localhost 80
Trying ::1...
Connection failed: Connection refused
Trying 127.0.0.1...
Connected to localhost.
Escape character is '^['.
```

```
fdasfdef
HTTP/1.1 400 Bad Request
Server: nginx/1.16.1
Date: Tue, 28 Apr 2020 20:09:37 GMT
Content-Type: text/html
Content-Length: 173
Connection: close

<html>
<head><title>400 Bad Request</title></head>
<body bgcolor="white">
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx/1.16.1</center>
</body>
</html>
Connection closed by foreign host.
```

Usa Telnet per connetterti alla porta 68. Cosa succede? Spiega.

```
[analyst@secOps ~]$ telnet localhost 68
Trying ::1...
Connection failed: Connection refused
Trying 127.0.0.1...
telnet: Unable to connect to remote host: Connection refused
```

Il tentativo di connessione fallisce istantaneamente con il messaggio **Connection refused** sia su IPv6 (::1) che su IPv4 (127.0.0.1).

Ecco la spiegazione tecnica del perché succede, incrociando questo dato con l'analisi che abbiamo fatto precedentemente con `netstat`:

- **Incompatibilità di Protocollo (Il motivo principale):** Telnet è uno strumento progettato per stabilire connessioni usando esclusivamente il protocollo **TCP** (cerca di eseguire il classico *3-way handshake*). Tuttavia, se ricordi l'output del comando **netstat** eseguito nella prima parte del laboratorio, la porta 68 era associata al protocollo **UDP** (il processo era **systemd-network**, ovvero il client DHCP che rinnova l'indirizzo IP della tua macchina). Poiché non c'è alcun servizio in ascolto in TCP su quella porta, il sistema operativo rifiuta attivamente la richiesta inviando un pacchetto di Reset (RST).
- **Indirizzo IP (Binding):** C'è anche un secondo fattore. Sempre nell'output di **netstat**, il servizio sulla porta 68 non era in ascolto su tutti gli indirizzi (**0.0.0.0**) o su localhost (**127.0.0.1**), ma era legato strettamente all'indirizzo IP specifico della scheda di rete (es. **192.168.x.x**). Digitando **telnet localhost 68**, stai "bussando" a un'interfaccia di rete su cui quel demone non sta prestando attenzione.

In sintesi, per i servizi basati su UDP (come DNS sulla porta 53, o DHCP sulle porte 67/68), **non puoi usare Telnet**. Per interagire con porte UDP durante un'attività di enumerazione, i professionisti della cybersecurity utilizzano strumenti differenti come **nc** (Netcat) in modalità UDP (es. **nc -u localhost 68**) o scanner dedicati.

Domande di Riflessione

1. Quali sono i vantaggi dell'uso di **netstat**?
2. Quali sono i vantaggi dell'uso di Telnet? è sicuro?

1. Quali sono i vantaggi dell'uso di **netstat**?

Lo strumento **netstat** (Network Statistics) è un pilastro fondamentale per l'amministrazione di sistema e per la fase di *Information Gathering* o di risposta a un incidente (Incident Response). I suoi vantaggi principali includono:

- **Mappatura della superficie di attacco:** Permette di vedere esattamente quali porte (TCP e UDP) sono aperte e in ascolto (**LISTEN**), rivelando quali servizi espongono la macchina a possibili interazioni esterne.
- **Correlazione di rete e processi:** Grazie all'opzione **-p** (eseguita come root), **netstat** collega inequivocabilmente una connessione di rete al suo Process ID (PID) e al nome del programma. Questo è vitale per smascherare malware: se vedi una porta sospetta aperta, **netstat** ti dice subito quale software la sta tenendo in piedi.
- **Rilevamento di anomalie:** Mostrando le connessioni stabilite (**ESTABLISHED**), permette a un analista di individuare traffico anomalo in uscita, come un server compromesso che comunica con un server Command & Control (C2) esterno.

(Nota: sui sistemi Linux moderni, **netstat** è considerato deprecato e viene progressivamente sostituito dal comando **ss**, che è più veloce e dettagliato, ma i principi operativi rimangono identici).

2. Quali sono i vantaggi dell'uso di Telnet? È sicuro?

I vantaggi di Telnet (come strumento diagnostico): Oggi Telnet viene utilizzato dai professionisti IT e Cybersecurity quasi esclusivamente come "coltellino svizzero" per testare le reti:

- **Verifica della connettività TCP:** È il modo più rapido per capire se un firewall sta bloccando una specifica porta TCP o se il server è raggiungibile (se la porta è chiusa dà **Connection refused**, se è filtrata va in timeout).
- **Banner Grabbing ed Enumerazione:** Come hai visto nel laboratorio con Nginx, Telnet permette di interagire manualmente con protocolli testuali (HTTP, SMTP, FTP, POP3) inviando comandi grezzi. Questo serve per costringere il demone a rivelare la sua identità e la sua versione esatta, fondamentale per cercare vulnerabilità (CVE) associate.

È sicuro? Assolutamente no. Per il suo scopo originario (l'amministrazione remota di dispositivi e server), Telnet è considerato **altamente insicuro**.

- **Nessuna crittografia:** Telnet trasmette l'intera sessione di comunicazione in **chiaro** (plaintext).
- **Esposizione delle credenziali:** Qualsiasi utente malintenzionato che intercetti il traffico di rete (ad esempio usando uno sniffer come Wireshark sulla stessa rete locale) può leggere in chiaro tutti i comandi inviati, inclusi gli username e le password usate per il login.
- **Nessuna integrità:** È vulnerabile ad attacchi *Man-in-the-Middle* (MitM), in cui un attaccante può iniettare comandi nella sessione senza che client e server se ne accorgano.

Per questi motivi, nella gestione remota delle infrastrutture, Telnet è stato completamente e doverosamente sostituito da **SSH (Secure Shell)**, che garantisce comunicazioni cifrate end-to-end.

Hai completato l'intera analisi del laboratorio? Se ci sono altri concetti che vuoi approfondire, sono a disposizione.